

The Incident Response Playbook

A complete, detailed guide to incident response —
from the first alert to the after-action report

*From triage to eradication to lessons learned, this playbook builds
the methodology and decision-making framework that turns individual
detection tools into an actual incident response capability.*

Author: Swastik Sagar
Final-year Computer Science Undergraduate
SOC Analyst Intern

August 19, 2026

Preface

Every other book in this series covers a tool or a technique — Wazuh, Splunk, Wireshark, Windows Event Logs, AD attacks. Incident response is what ties all of it together into an actual capability: knowing what to do, in what order, when one of those tools produces a real finding at 2 a.m. and a decision has to be made under uncertainty and time pressure.

This playbook follows the incident response lifecycle in the order a real incident actually unfolds — preparation before anything happens, identification and triage when an alert first arrives, containment strategies that stop the bleeding without destroying evidence, eradication and recovery, and the post-incident work that turns one bad day into a permanently better security posture. Later chapters cover runbooks, communication, common incident types, tabletop exercises, and the legal considerations that shape real-world response.

What this book covers

- The incident response lifecycle and the frameworks it's built on
- Preparation: what has to be in place before an incident happens
- Identification and triage: turning an alert into a scoped incident
- Containment strategies and the trade-offs between them
- Eradication and recovery
- Post-incident activity and lessons-learned processes
- Building and using runbooks
- Communication during an incident, internal and external
- Common incident types: ransomware, business email compromise, insider threat, data breach
- Tabletop exercises and IR program readiness
- Legal and regulatory considerations

Swastik Sagar

Contents

Preface	i
1 The Incident Response Lifecycle	1
1.1 Why a formal lifecycle matters	1
1.2 The six phases	1
2 Preparation	2
2.1 What has to be in place beforehand	2
2.2 The incident response plan	2
2.3 Building an incident response team	3
3 Identification and Triage	4
3.1 From alert to incident	4
3.2 Triage questions	4
3.3 Severity classification	4
4 Containment Strategies	5
4.1 The core tension	5
4.2 Short-term vs. long-term containment	5
4.3 Common containment actions	6
5 Eradication	7
5.1 Removing the root cause	7
5.2 Eradication activities	7
5.3 Verifying eradication is complete	7
6 Recovery	8
6.1 Returning to normal operations safely	8
6.2 Recovery activities	8
7 Post-Incident Activity	9
7.1 The lessons-learned meeting	9
7.2 Structuring the review	9
7.3 The after-action report	9

8	Building and Using Runbooks	10
8.1	What a runbook is	10
8.2	What a good runbook includes	10
9	Communication During an Incident	11
9.1	Internal communication	11
9.2	External communication	11
10	Common Incident Types	12
10.1	Ransomware	12
10.2	Business Email Compromise (BEC)	12
10.3	Insider threat	12
10.4	Data breach	12
11	Tabletop Exercises and IR Readiness	14
11.1	Why tabletop exercises matter	14
11.2	Running an effective tabletop	14
12	Legal and Regulatory Considerations	15
12.1	Why legal involvement matters early	15
12.2	Common regulatory considerations	15
12.3	Evidence handling and chain of custody	15

The Incident Response Lifecycle

1.1 Why a formal lifecycle matters

Under the pressure of an active incident, it's easy to skip steps — jumping straight to remediation before scope is understood, or containing a threat in a way that destroys the evidence needed to understand it. A consistent lifecycle exists specifically to prevent these predictable mistakes when it matters most.

1.2 The six phases

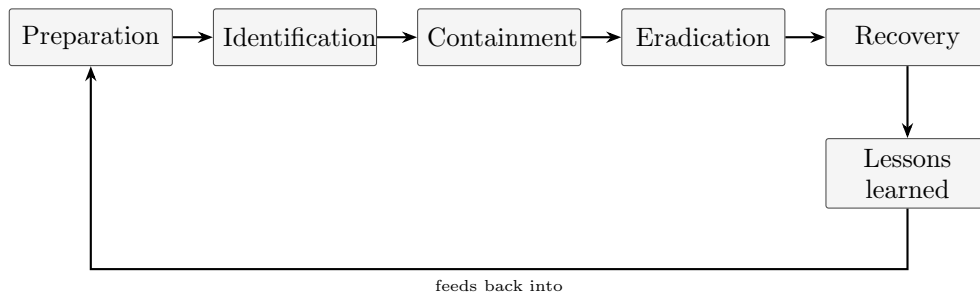


Figure 1.1. Based on the NIST and SANS incident response frameworks – lessons learned always feeds back into preparation, making this a cycle, not a line.

Phase	Core question
Preparation	Are we ready before anything happens?
Identification	Is this actually an incident, and what's the scope?
Containment	How do we stop it from getting worse right now?
Eradication	How do we remove the root cause completely?
Recovery	How do we safely return to normal operations?
Lessons learned	What do we change so this doesn't happen again?

NIST vs. SANS phase naming

NIST SP 800-61 uses four phases (merging containment/eradication/recovery into one); SANS uses six, splitting them out individually as shown above. The underlying activities are the same either way — this book follows the six-phase breakdown since it maps more directly onto distinct decisions an analyst actually has to make.

Preparation

2.1 What has to be in place beforehand

- An IR plan and defined roles, written down before an incident, not improvised during one
- Logging and detection coverage sufficient to actually identify an incident (see the SIEM and Wazuh playbooks)
- Defined escalation paths and contact information, including outside normal business hours
- Pre-approved containment actions where possible, reducing decision latency during a real event
- Forensic readiness: imaging capability, evidence handling procedures, chain of custody process

2.2 The incident response plan

Plan component	Purpose
Roles and responsibilities	Who does what, avoiding confusion when it matters most
Severity classification	A shared definition of what makes an incident low/medium/high/critical
Escalation criteria	When and to whom an incident gets escalated
Communication templates	Pre-drafted language for common notification needs
Tool and access inventory	What's available, and who has access to use it

A plan nobody has read is not a plan

An IR plan that exists only as a document nobody has reviewed recently is functionally the same as having no plan — regular review and, ideally, tabletop exercises (covered in chapter 10) are what actually make a written plan useful under real pressure.

2.3 Building an incident response team

Role	Responsibility
Incident commander	Owens the overall response, coordinates across roles
Lead analyst	Drives technical investigation and containment decisions
Communications lead	Manages internal and external notifications
Legal/compliance	Advises on regulatory and legal obligations

Identification and Triage

3.1 From alert to incident

Not every alert is an incident, and triage exists to make that determination quickly and consistently — confirming something real is happening, establishing an initial scope, and assigning a severity before committing significant resources to a full response.

3.2 Triage questions

- What exactly triggered this, in plain terms — not just the alert name?
- Is this consistent with expected/authorized activity for this host or account?
- What is the earliest evidence of this activity, and is it still ongoing?
- What is the potential blast radius if this is confirmed malicious?

3.3 Severity classification

Severity	Typical criteria
Low	Contained, no evidence of lateral movement or data impact
Medium	Confirmed malicious activity, limited scope, no confirmed data impact
High	Active compromise with lateral movement, privileged access, or likely data impact
Critical	Confirmed significant data breach, ransomware detonation, or business-critical system impact

Scope creep is expected, not a failure

Initial scope during triage is almost always wrong in one direction or another — treating the first assessment as provisional, and building in a habit of re-scoping as new evidence arrives, is normal incident response practice, not a sign the initial triage was done poorly.

Containment Strategies

4.1 The core tension

Containment has to balance two competing goals: stopping the incident from getting worse, and preserving the evidence and access needed to fully understand what happened — moving too fast in either direction has real costs.

Strategy	Trade-off
Immediate isolation	Stops damage fastest, but may alert the attacker and lose in-memory evidence
Monitored containment	Preserves more evidence and intelligence, but the incident continues during observation
Segmentation	Limits spread without fully isolating, balancing both goals but slower to implement

4.2 Short-term vs. long-term containment



Figure 4.1. *Short-term containment (e.g. a firewall block) buys time; evidence capture happens before long-term containment changes the environment further.*

Capture evidence before you contain, where possible

Isolating a host before capturing memory or a disk image can destroy exactly the evidence needed to understand the incident — where operationally feasible, evidence capture should happen as close to simultaneously with containment as possible, not strictly afterward.

4.3 Common containment actions

Action	Use case
Network isolation	Cut a compromised host off from the network while preserving it for forensics
Account disablement	Stop use of a compromised credential immediately
Firewall/WAF rule addition	Block a specific malicious IP or pattern without touching the affected host
DNS sinkholing	Redirect malicious domain resolution, disrupting C2 without alerting via a network block

Eradication

5.1 Removing the root cause

Containment stops the immediate damage; eradication removes what caused it in the first place — the malware, the compromised account, the vulnerability that allowed initial access — so the same incident can't simply happen again the moment containment is lifted.

5.2 Eradication activities

- Remove malware, backdoors, and any persistence mechanisms identified during investigation
- Reset credentials for every account confirmed or suspected to be compromised
- Patch or otherwise close the vulnerability that enabled initial access
- Rebuild severely compromised systems from known-good images rather than attempting to fully clean them

Rebuild vs. clean, as a real decision

For a host with deep or uncertain compromise (especially anything suggesting rootkit-level or kernel-level access), rebuilding from a known-good image is usually faster and more trustworthy than attempting to manually clean every artifact — confidence in "clean" is hard to achieve any other way.

5.3 Verifying eradication is complete

- Confirm no remaining indicators of compromise across the environment, not just the originally affected systems
- Verify patches or configuration changes actually took effect, not just that they were scheduled
- Re-scan or re-image systems as appropriate before returning them to production

Recovery

6.1 Returning to normal operations safely

Recovery is deliberately its own phase, separate from eradication — bringing systems back online too quickly, without validation, risks reintroducing the same incident before anyone’s confirmed the underlying cause is actually gone.

6.2 Recovery activities

- Restore systems from clean backups or verified-clean rebuilds
- Monitor restored systems closely for any recurrence of the original indicators
- Gradually restore access and services rather than all at once, where feasible
- Confirm with stakeholders before declaring the incident formally closed

Consideration	Why it matters
Backup integrity	A backup taken during the compromise window may itself be compromised
Heightened monitoring period	A defined window of extra scrutiny after recovery, not just a return to baseline immediately
Staged restoration	Limits the blast radius if the root cause wasn’t actually fully eradicated

Check backup timestamps against the compromise window

Restoring from a backup taken after initial compromise but before detection can silently reintroduce the exact problem being recovered from — confirming backup timestamps against the established timeline is a step worth double-checking, not assuming.

Post-Incident Activity

7.1 The lessons-learned meeting

Held after the incident is fully resolved, with every involved party present — the goal is a blameless, factual review of what happened, what worked, what didn't, and what should change, not an exercise in assigning fault.

7.2 Structuring the review

- Build a factual timeline first, agreed upon by everyone, before discussing interpretation or blame
- Identify what detection worked, what didn't, and why
- Identify what response actions helped, what slowed things down, and why
- Convert findings into specific, owned, tracked action items — not just general observations

7.3 The after-action report

Section	Contents
Executive summary	Plain-language overview for non-technical stakeholders
Timeline	Detailed, timestamped sequence of events and response actions
Root cause	What specifically allowed the incident to happen
Impact assessment	What was actually affected, as precisely as can be determined
Action items	Specific, owned follow-up work with target dates

Blameless doesn't mean consequence-free

A blameless review focuses on systemic and process factors rather than individual fault-finding, which produces more honest information and better fixes — it doesn't mean ignoring genuine negligence, but the review process itself works better when people aren't reflexively protecting themselves during the fact-finding.

Building and Using Runbooks

8.1 What a runbook is

A runbook is a predefined, step-by-step procedure for handling a specific type of incident — reducing decision latency and inconsistency during an actual event by working through decisions in advance, when there's time to think clearly.

8.2 What a good runbook includes

- Clear triggering criteria: exactly when this runbook applies
- Step-by-step actions, in order, with owners for each step
- Decision points explicitly called out, with criteria for each branch
- Required tools, access, and contacts for this specific incident type
- Escalation criteria if the situation exceeds the runbook's assumptions

A simplified runbook excerpt: suspected ransomware

1. Isolate affected host(s) from the network immediately
2. Preserve memory/disk image before further action, if feasible
3. Identify ransomware family via file extension/ransom note if possible
4. Check backup availability and integrity for affected systems
5. Escalate to incident commander -- do not negotiate or pay independently
6. Begin scoping: what else does this account/host have access to

Runbooks are living documents

A runbook that hasn't been updated since it was written is drifting from reality as tools, infrastructure, and contacts change — reviewing and updating runbooks after every relevant incident (and on a regular schedule regardless) keeps them actually usable.

Communication During an Incident

9.1 Internal communication

- A single, designated channel for incident coordination, avoiding fragmented information across many threads
- Regular status updates on a defined cadence, even when there's no major update, to prevent stakeholder anxiety-driven interruptions
- Clear ownership of who communicates what, to avoid conflicting information reaching leadership

9.2 External communication

Audience	Consideration
Customers	Timing and content often has legal/regulatory requirements, not just PR judgment
Regulators	Specific notification deadlines apply depending on jurisdiction and data type
Law enforcement	May need to be engaged depending on incident type and organizational policy
Media	Should route through a single, prepared spokesperson, never ad hoc

Don't speculate in early communications

Early incident communications should stick to confirmed facts and avoid speculating about scope, cause, or impact before investigation confirms them — premature statements that later prove wrong damage credibility far more than a measured "investigation is ongoing" update does.

Common Incident Types

10.1 Ransomware

- Isolate immediately to prevent further spread across the network
- Identify the specific ransomware family, which often determines available decryption options
- Assess backup viability before considering any other recovery path
- Involve legal counsel before any consideration of payment, given the regulatory and sanctions complexity involved

10.2 Business Email Compromise (BEC)

- Immediately reset credentials and review mailbox rules for the compromised account (attackers frequently add hidden forwarding rules)
- Review sent mail for any fraudulent financial requests already issued
- Check for OAuth app grants or mailbox delegation added during the compromise window
- Notify financial contacts if any payment-related communication may have been affected

10.3 Insider threat

- Involve HR and legal early — insider cases carry different procedural requirements than external attacks
- Preserve evidence carefully, since insider cases are more likely to proceed to formal disciplinary or legal action
- Balance investigation thoroughness against the risk of tipping off the individual prematurely

10.4 Data breach

- Determine exactly what data was accessed or exfiltrated, as precisely as evidence allows
- Determine applicable notification obligations based on data type and jurisdiction
- Coordinate notification timing carefully with legal counsel, since deadlines vary significantly by regulation

Every incident type still follows the same lifecycle

These aren't separate methodologies — they're the same six-phase lifecycle from chapter 1, with type-specific considerations layered on top at each phase. The lifecycle is what stays constant; the specifics of each phase are what a runbook for that incident type actually

captures.

Tabletop Exercises and IR Readiness

11.1 Why tabletop exercises matter

A tabletop exercise walks a team through a simulated incident scenario without any real systems involved — testing the plan, the runbooks, and the team’s decision-making under a realistic (if artificial) sequence of events, before a real incident does the same testing for real.

11.2 Running an effective tabletop

- Choose a realistic scenario relevant to the organization’s actual environment and threat model
- Introduce complications partway through — real incidents rarely unfold as cleanly as an initial plan assumes
- Include all roles that would actually be involved, not just the technical team
- Capture gaps and action items with the same rigor as a real lessons-learned session

Exercise type	Focus
Discussion-based tabletop	Walk through decisions verbally, no real actions taken
Functional exercise	Some real actions performed (e.g. actually isolating a test host)
Full-scale exercise	As close to a real incident as safely possible, often unannounced to some participants

Frequency matters more than perfection

A simple tabletop run quarterly finds more real gaps over time than one elaborate exercise run once a year — regular, lower-effort practice builds the muscle memory that matters far more during an actual incident than a single polished exercise does.

Legal and Regulatory Considerations

12.1 Why legal involvement matters early

Legal counsel should be involved from early in a significant incident, not brought in only once notification decisions are unavoidable — attorney-client privilege considerations, evidence handling requirements, and regulatory deadlines all affect decisions made throughout the response, not just at the end.

12.2 Common regulatory considerations

Framework	Relevance
GDPR	Strict, short notification deadlines for personal data breaches affecting EU residents
HIPAA	Specific breach notification requirements for protected health information
PCI DSS	Card brand notification requirements for payment card data incidents
State/national breach laws	Vary significantly by jurisdiction, often with their own specific deadlines

12.3 Evidence handling and chain of custody

- Document who collected each piece of evidence, when, and how
- Maintain integrity verification (hashing) for any forensic image from the moment it's captured
- Store evidence securely with access logging, in case it's later needed for legal proceedings
- Treat every incident as potentially litigation-relevant from the start, even if it doesn't end up that way

This is why legal and technical work together, not sequentially

Waiting until an incident is "confirmed serious enough" to involve legal counsel risks having already taken actions or made statements that complicate the legal and regulatory response later — early involvement costs little and closes off very few options, while late involvement can foreclose options that mattered.